

MARCO INTEGRATIVO GQM+ PRAGMATIC PARA INDICADORES OWASP SAMM

Trazabilidad desde Objetivos Nacionales hasta Métricas Técnicas Operacionales

Versión: 1.0 | **Fecha:** Enero 2026 | **Ámbito:** España e Internacional

Metodología: GQM (Goal-Question-Metric) + GQM+Strategies + PRAGMATIC (9 Criterios)

Público: CISOs, Estrategas de Ciberseguridad, Consultores, Investigadores

INTRODUCCIÓN EJECUTIVA

Este documento articula un **marco integrativo riguroso** que conecta:

1. Objetivos Nacionales Españoles (NIS2, CRA, GDPR, ENS, normativa sectorial)
2. Estrategias Organizacionales de Negocio (mediante GQM+Strategies de Basili)
3. Objetivos de Ciberseguridad (funciones SAMM v2)
4. Preguntas Operacionales (¿qué queremos saber?)
5. Métricas Técnicas Específicas (datos cuantificables)
6. Evaluación PRAGMATIC (9 criterios de calidad)

Propósito: Asegurar que cada métrica de ciberseguridad sea **trazable, justificable, operacional y de alto valor**.

PARTE I: NIVEL 0 — OBJETIVOS NACIONALES ESTRATÉGICOS (España 2025-2026)

I.1 Contexto Normativo Obligatorio

Regulación	Entrada Vigencia	Plazo Implementación Nacional	Objetivo Clave	Aplicación SAMM
NIS2	Ene 2023	Oct 2024 (ya vencido)	Resiliencia operacional de esenciales/import antes	SAMM L1.8+ Gobernanza, Operaciones
CRA	Dic 2024	Sept 2026 (técnico)	Seguridad por diseño en productos digitales	SAMM L1.55+ Diseño, Implementación, Verificación
DORA	Ene 2023	Vigente (sector financiero)	Resiliencia operacional digital	SAMM L2+ Operaciones, Gobernanza
GDPR	May 2018	Vigente	Protección datos personales	SAMM L2+ Implementación, Operaciones (Data Protection)
ENS	Vigente	Aplicable Administración Pública	Estándares seguridad pública	SAMM L1.8+ todas funciones

I.2 Objetivos Nacionales Explícitos (Derivados de Normativa)

Objetivo Nacional 1: Eliminar Vulnerabilidades Críticas en Infraestructura Esencial

Statement: "Reducir en 50% el tiempo promedio entre descubrimiento y remediación de vulnerabilidades críticas en operadores esenciales españoles para 2026."

Contexto: INCIBE 2024 registró 341 incidentes a operadores esenciales; 48h promedio MTTD global (CrowdStrike).

Alineación Regulatoria: NIS2 Art. 21 (obligación de gestión de riesgos), CRA Annex I (vulnerability handling).

Impacto de Negocio: Reducción de costo de incidentes, continuidad operacional, confianza del público.

Objetivo Nacional 2: Madurez de Seguridad en Desarrollo de Software

Statement: "Alcanzar madurez SAMM L1.8 promedio en 80% de operadores esenciales españoles en Design + Verification para 2026."

Contexto: SAMM benchmark global actual 1.44/3.0; CRA requiere L1.55 mínimo.

Alineación Regulatoria: CRA Annex I (Secure by Design), NIS2 Art. 20 (medidas técnicas).

Impacto de Negocio: Defectos descubiertos pre-producción, reducción costo remediación, confianza en software.

Objetivo Nacional 3: Capacitación y Conciencia en Seguridad

Statement: "90%+ de empleados en sector crítico completan capacitación en ciberseguridad anualmente con validación de cambio de comportamiento."

Contexto: INCIBE 2024 muestra 67.6% incidentes afectan ciudadanía; phishing sigue siendo 22% de ataques.

Alineación Regulatoria: NIS2 Art. 21 (obligación de capacitación), GDPR Art. 32 (sensibilización).

Impacto de Negocio: Reducción de clics en phishing, menor surface de ataque, resiliencia organizacional.

I.3 Estrategias Organizacionales (Nivel GQM+Strategies)

Para una organización operadora esencial española típica:

Objetivo Nacional	Estrategia Organizacional	Objetivo Software-Específico	Horizonte
Eliminar vulns críticas	Implementar SIEM con ML; mejorar MTDD/MTTR	"MTTD crítica: 4h; MTTR 24h"	2026 Q2
Madurez SAMM L1.8	Threat modeling + secure SDLC	"100% aplicaciones críticas con threat model; SAST/DAST estándar"	2026 Q3
Capacitación 90%+	Programa modular + phishing simulation	"85%+ phishing click-rate < 5%; training completion 95%+"	2026 Q1

PARTE II: NIVEL 1 — OBJETIVOS GQM (GOAL LEVEL)

II.1 Estructura de Goals (SAMM + Regulatory Alignment)

Para cada **función SAMM** + **objetivo nacional**, definimos un **Goal** formal usando template GQM+Strategies.

Template GQM+Strategies Goal:

Activity: [Acción principal]
Focus: [Atributo de calidad]
Object: [Qué se mide]
Magnitude: [Meta cuantificada]
Timeframe: [Plazo]
Context: [Condiciones, factores ambientales]
Stakeholders: [Quién es responsable/interesado]
Assumptions: [Supuestos operacionales]

II.2 Ejemplos de Goals Derivados de Objetivos Nacionales

GOAL 1: Mejorar Gobernanza de Seguridad de Software

Activity: Implementar
Focus: Madurez en documentación y comunicación de estrategia
Object: Programa de seguridad de aplicaciones (AppSec)
Magnitude: Score Gobernanza SAMM 1.4 → 1.8 (+29%)
Timeframe: 18 meses (Q2 2026)
Context: Operador esencial español; sector financiero/telecom
Stakeholders: CISO, CIO, Board de Directores
Assumptions: Presupuesto disponible (~€100k); talento interno
Rationale: NIS2 Art. 20 requiere governance; CRA Annex I exige.

Link a Objetivo Nacional: — "Alcanzar madurez SAMM L1.8 en Design+Verification"

GOAL 2: Acelerar Detección de Incidentes (MTTD)

Activity: Mejorar
Focus: Velocidad de detección
Object: Incidentes en aplicaciones críticas
Magnitude: MTTD: 48h → 4h (12x mejora); cobertura de detección 95%+
Timeframe: 12 meses (Q2 2026)
Context: SIEM existente; SOC pequeño (~2-3 FTE); datos: 500GB/día
Stakeholders: SOC Manager, Security Team, CISO
Assumptions: Inversión SIEM ML ~€50k; personal adicional 1 FTE
Rationale: INCIBE 2024 promedio 48h; requerimiento NIS2 operacional

Link a Objetivo Nacional: — "Eliminar vulnerabilidades críticas en 50% tiempo"

GOAL 3: Reducir Phishing Click Rate

Activity: Entrenar y Medir
Focus: Comportamiento de empleados ante phishing
Object: Empleados en sector esencial
Magnitude: Click rate: 15% → <5%; reporting rate: 10% → 60%+
Timeframe: 12 meses (Q1 2026)
Context: 2500+ empleados; 40% remote; sector financiero
Stakeholders: Security Awareness Lead, HR, Management
Assumptions: Simulaciones mensuales; presupuesto training €30k/año
Rationale: GDPR Art. 32 sensibilización; 22% incidentes son phishing

Link a Objetivo Nacional: — "90%+ capacitación anual con validación comportamiento"

PARTE III: NIVEL 2 — PREGUNTAS GQM (QUESTION LEVEL)

III.1 Metodología de Preguntas

Para cada **Goal**, derivamos **2-4 Preguntas operacionales** que:

- Caracterizan el estado actual vs. target
- Focalizan el objeto de medición
- Son respondibles mediante datos cuantitativos

Template Pregunta GQM:

Question: [¿Qué queremos saber?]
 Focus: [Atributo específico]
 Object: [Sobre qué entidad]
 Timeframe: [Período de medición]

III.2 Ejemplos de Preguntas por Goal

Para **GOAL 1 (Gobernanza)**:

#	Pregunta	Objeto	Atributo
G1.1	¿Existe documentada formalmente una estrategia plurianual de seguridad de software?	Estrategia AppSec	Existencia, formalización
G1.2	¿Con qué frecuencia se comunica y revisa la estrategia con stakeholders?	Comunicación	Frecuencia, cobertura
G1.3	¿Existen métricas definidas para medir éxito de la estrategia?	KPIs	Compleitud, validez
G1.4	¿Qué porcentaje de aplicaciones y equipos alinean sus actividades con la estrategia?	Conformidad	Cobertura, consistencia

Para GOAL 2 (MTTD):

#	Pregunta	Objeto	Atributo
O2.1	¿Cuál es el tiempo PROMEDIO (en horas) para detectar un incident desde que ocurre?	MTTD	Media, mediana, distribución
O2.2	¿Cuál es el PERCENTIL 95 de MTTD (peor 5%)?	MTTD tail risk	Variabilidad, casos extremos
O2.3	¿Qué % de incidentes son detectados automáticamente (SIEM/SOC) vs. reportados externamente?	Detection source	Autonomous detection rate
O2.4	¿Cuáles son los 3 principales motivos de retrasos en detección?	Root causes	Categorización, frecuencia

Para GOAL 3 (Phishing):

#	Pregunta	Objeto	Atributo
T3.1	¿Cuál es la tasa de FALLO en simulaciones de phishing (% que clickean)?	Click rate	Media, distribución por rol
T3.2	¿Cuál es el tiempo PROMEDIO entre recepción de phishing y reporte a seguridad?	Report time	Media, mediana, <10min %
T3.3	¿Cuántos empleados completaron training de seguridad en el último año?	Training coverage	% cumplimiento
T3.4	¿Hubo mejora en click rate post-training? ¿De cuánto?	Training effectiveness	Before/after comparison

PARTE IV: NIVEL 3 — MÉTRICAS GQM (METRIC LEVEL)

IV.1 Definición de Métricas

Para cada **Pregunta**, definimos **1-2 Métricas operacionales** que:

- Son cuantificables, objetivas
- Pueden ser automatizadas o semi-automatizadas

- Tienen fuente de datos clara
- Son interpretables para stakeholders

Template Métrica QM:

Metric Name: [Nombre]
 Definition: [Fórmula o algoritmo]
 Unit: [Unidad de medida]
 Data Source: [Dónde viene el dato]
 Collection Method: [Cómo se recopila]
 Frequency: [Con qué frecuencia se calcula]
 Interpretation: [Qué significa el valor]
 Target: [Meta]
 Owned By: [Responsable]

IV.2 Matriz de Métricas por Dominio SAMM

A. GOBERNANZA (Governance)

Pregunta G1.1: ¿Existe documentada formalmente una estrategia plurianual de seguridad de software?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Strategy Documentation Score	¿Estrategia en documento formal (SharePoint/ Wiki)? + ¿Actualizada <12 meses? + ¿Accesible a stakeholders?	0-3	Wiki seguridad	Anual	3
Strategy Stakeholder Awareness	% de stakeholders que pueden articular estrategia	%	Survey/ Entrevistas	Semestral	80%+

Pregunta G1.2: ¿Con qué frecuencia se comunica la estrategia?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Strategy Review Frequency	# de revisiones formales + # sesiones comunicación / 12 meses	Count/año	Calendar de reuniones	Mensual	6-12 sesiones
Strategy Cascade Breadth	% de empleados que han oído hablar de la estrategia (post-comunicación)	%	Post-survey	Trimestral	70%+

Pregunta G1.3: ¿Existen métricas definidas para medir éxito?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
KPI Completeness	# de KPIs definidos para la estrategia (min: 5)	Count	Documento de estrategia	Anual	5-10 KPIs
KPI Tracking Rate	# de KPIs tracked y reportados mensualmente / # total KPIs	%	Dashboard de métricas	Mensual	100%

B. DISEÑO (Design)

Pregunta D1.1: ¿Qué porcentaje de aplicaciones críticas tienen threat model documentado?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Threat Model Coverage	# aplicaciones críticas con threat model documentado / # aplicaciones críticas totales	%	SAMM assessment, repo	Trimestral	100%
Threat Model Age	Promedio de meses desde última actualización de threat model	months	Repositorio modelos	Mensual	<12 meses
STRIDE Coverage per Model	# de elementos STRIDE explícitamente analizados (min 6)	Count	Review de modelos	Trimestral	6/6

Pregunta D1.2: ¿Cuántas vulnerabilidades de diseño fueron detectadas pre-producción?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Arch Findings Count	# de hallazgos de arquitectura en reviews anuales	Count	Defect tracker	Trimestral	5-15 críticos/año
Pre-Prod Closure Rate	# hallazgos cerrados antes de producción / # hallazgos totales	%	Defect tracker	Mensual	95%+

C. IMPLEMENTACIÓN (Implementation)

Pregunta I1.1: ¿Qué porcentaje de builds tienen security gates automáticos?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
SAST Integration Coverage	# de aplicaciones con SAST en CI/CD / # total	%	CI/CD logs (Jenkins/GitLab)	Diario	100%
Build Gate Block Rate	# de builds bloqueados por vulnerabilidad detectada / # builds totales	%	CI/CD logs	Diario	>5% (indica rigor)
SCA Vuln Detection Rate	# de componentes vulnerables detectados por SCA / #componentes analizados	%	SCA tool logs	Diario	>2% (benchmark)

Pregunta I1.2: ¿Cuántas vulnerabilidades se detectan en build vs. producción?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Pre vs Post-Deploy Vuln Ratio	# vulns cerradas en build / # vulns encontradas en producción	ratio	SAST logs + Incident log	Mensual	5:1 o mayor

D. VERIFICACIÓN (Verification)

Pregunta V1.1: ¿Qué porcentaje de requisitos de seguridad tienen test cases?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Security Test Coverage	# requisitos de seguridad con test cases / # total req. seguridad	%	Test repository, ALM	Mensual	85%+
Test Execution Rate	# tests de seguridad ejecutados / # tests definidos (últimos 3 meses)	%	Test reports	Mensual	95%+

Pregunta V1.2: ¿Con qué frecuencia se realizan penetration tests?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Pentest Frequency	# pen tests realizados en último año	Count/año	Pentest reports	Anual	2-4 (mínimo 1)
Pentest Finding Closure	# hallazgos críticos cerrados / # hallazgos totales	%	Pentest tracker	Post-pentest	100% críticos

E. OPERACIONES (Operations)

Pregunta O1.1: ¿Cuál es el MTTD (Mean Time To Detect) actual?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
MTTD Mean	Promedio de horas desde occurrence hasta detection (últimos 90 días)	hours	SIEM/ Incident log	Diario	<4h (crítica); <24h (alto)
MTTD Median	Mediana de horas MTDD	hours	SIEM/ Incident log	Diario	<1h
MTTD P95	Percentil 95 (peor 5%) de MTDD	hours	SIEM/ Incident log	Semanal	<48h
Autonomous Detection %	# incidents detectados automáticamente (SIEM/SOC) / # totales	%	Incident classification	Mensual	80%+

Pregunta O1.2: ¿Cuál es el MTTR (Mean Time To Remediate)?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
MTTR Critical	Promedio horas remediación vulnerabilidad CRÍTICA	hours	Incident log	Mensual	<24h
MTTR High	Promedio horas remediación vulnerabilidad ALTA	hours	Incident log	Mensual	<7 días
MTTR Compliance %	% de remediaciones que cumplen SLA	%	Incident tracking	Mensual	95%+

Pregunta 01.3: ¿Qué porcentaje de sistemas están patchados dentro del SLA?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Patch Compliance Crítica	# sistemas parchados en <24h / # críticos identificados	%	Patch management tool	Diario	100%
Patch Compliance Alta	# sistemas parchados en <7d / # altos identificados	%	Patch management tool	Diario	95%+
Patch Lag Days	Promedio de días entre release y aplicación	days	Patch tool	Mensual	<7 días

F. ANÁLISIS DE VULNERABILIDADES

Pregunta V2.1: ¿Con qué frecuencia se escanean vulnerabilidades?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Scan Coverage %	# sistemas/apps escaneados en último mes / # total	%	Vulnerability scanner logs	Mensual	90%+
Scan Frequency	Escaneos por sistema/año	Count/año	Scanner config	Mensual	12+ (semanal o más)

Pregunta V2.2: ¿Cómo se priorizan vulnerabilidades detectadas?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Prioritization Sophistication	Score: 1=CVSS only; 2=CVSS+context; 3=CVSS+EPSS+context	1-3	Process doc	Trimestral	3
Vuln with EPSS Score	% de vulnerabilidades con puntuación EPSS (exploitabilidad)	%	Vuln database	Mensual	80%+

G. SIEM Y OPERACIONES DE SEGURIDAD

Pregunta S1.1: ¿Cuál es la cobertura de fuentes de datos en el SIEM?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
SIEM Data Source Coverage	# tipos de fuentes de datos enviando logs / # definidos en arquitectura	%	SIEM inventory	Mensual	95%+
Log Volume Daily	GB de logs ingestados / día	GB	SIEM dashboard	Diario	Baseline + trend
Data Availability %	% tiempo SIEM activo y ingiriendo logs	%	SIEM uptime logs	Diario	99%+

Pregunta S1.2: ¿Cuál es la calidad de detecciones en SIEM?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
False Positive Rate	# alertas falsas / # alertas totales (últimos 30 días)	%	SIEM alert review	Mensual	<30%
Alert to Incident Conversion	# alerts que resultan en incident / # total alerts	%	Incident correlation	Mensual	5-15% (depende reglas)
Detection Timeliness	Tiempo promedio desde trigger hasta alert generada	seconds	SIEM logs	Diario	<5 min

H. CAPACITACIÓN Y CONCIENCIA

Pregunta T1.1: ¿Qué porcentaje de empleados completó capacitación anual?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Training Completion Rate	# empleados completaron training / # empleados totales	%	LMS (Learning Management System)	Mensual	95%+
Training Hours per Capita	Horas totales training / # empleados	hours/employee	LMS	Trimestral	8+ horas/año

Pregunta T1.2: ¿Cuál es la tasa de fallo en simulaciones de phishing?

Métrica	Definición	Unit	Fuente	Frecuencia	Target
Phishing Click Rate	# empleados que clickearon en simulación / # total exposición	%	Phishing simulator	Mensual	<5%
Report Rate	# empleados que reportaron phishing / # exposición	%	Phishing simulator	Mensual	>60%
Time to Report	Promedio minutos desde recepción a reporte	minutes	Phishing simulator	Mensual	<10 min (ideal)
Click Rate Trend	Mejora mes-a-mes (%)	% change	Phishing simulator	Mensual	-3% a -5%/mes (mejoría)

PARTE V: EVALUACIÓN PRAGMATIC (9 CRITERIOS)

V.1 Los 9 Criterios PRAGMATIC

Cada métrica es evaluada contra estos 9 criterios para determinar su **calidad, utilidad y viabilidad**:

#	Criterio	Definición	Escala
1	Predictivo	¿Predice comportamiento futuro o riesgos próximos?	1-5
2	Relevante	¿Es importante para stakeholders (negocio, regulación, técnico)?	1-5
3	Accionable	¿Permite tomar decisiones u acciones concretas?	1-5
4	Genuino	¿Refleja la realidad operacional sin artifice?	1-5
5	Meaningful	¿Es significativo, no trivial; tiene profundidad?	1-5
6	Acurado	¿Se puede medir con precisión y confiabilidad?	1-5
7	Toportuno	¿Está disponible con frecuencia suficiente (tempo operacional)?	1-5
8	Independiente	¿No depende de otros para interpretación? ¿Es auto-suficiente?	1-5
9	Costeable	¿El costo de recopilación es razonable vs. valor?	1-5

Escala de Evaluación:

- 1 = Muy débil / No cumple
- 2 = Débil / Cumple parcialmente
- 3 = Aceptable / Cumple moderadamente
- 4 = Fuerte / Cumple bien
- 5 = Excelente / Cumple totalmente

V.2 Ejemplos de Evaluación PRAGMATIC

Métrica: MTTD Mean

Metric: MTTD Mean (Mean Time To Detect - Promedio)

Definition: Promedio de horas desde occurrence hasta detection (últimos 90 días)

Evaluación PRAGMATIC:

P (Predictivo):	5/5 - MTTD es PREDICTOR de eficacia SOC; si MTTD aumenta, impacto potencial aumenta exponencialmente
R (Relevante):	5/5 - Crítico para NIS2 (Art. 20), regulación financiera, riesgo de negocio
A (Accionable):	4/5 - Permite decisiones: invertir en SIEM, contratar SOC, mejorar reglas. (Menos accionable si causa raíz es desconocida)
G (Genuino):	4/5 - Refaja realidad; pero puede ser sensible a definición de "detection" (automático vs. manual)
M (Meaningful):	5/5 - Muy significativo; diferencia entre 48h y 4h es 12x; impacto material
A (Acurado):	4/5 - Medible con precisión si timestamps son confiables (depende de SIEM/logs)
T (Oportuno):	5/5 - Disponible DIARIO desde SIEM; frecuencia operacional ideal
I (Independiente):	3/5 - Requiere contexto (¿qué tipo de incident? ¿la definición de "detection"?). Mejor con segmentación por tipo.
C (Costeable):	5/5 - Extraído de SIEM ya existente; costo marginal ~\$0
PRAGMATIC Score:	$(5+5+4+4+5+4+5+3+5) / 9 = 40/45 = 88.9\% \rightarrow$ EXCELENTE
Recomendación:	ADOPTAR; métrica de alta prioridad, casi todos los criterios satisfechos

Métrica: Phishing Click Rate

Metric: Phishing Click Rate

Definition: % de empleados que clickean en simulación / total exposición

Evaluación PRAGMATIC:

P (Predictivo):	4/5 - Predice vulnerabilidad a phishing real; correlación ~70% con incidents reales
R (Relevante):	4/5 - Importante para GDPR, NIS2 capacitación; menos para board que ciberseguridad técnica
A (Accionable):	5/5 - Permite acción directa: training, políticas, reporte, coaching individual
G (Genuino):	3/5 - Representa comportamiento simulado, no real. Sesgo: empleados pueden estar más atentos sabiendo que hay simulación
M (Meaningful):	4/5 - Significativo pero fácil de "jugar" artificialmente; requiere comparativa
A (Acurado):	5/5 - Medible con alta precisión por herramienta de simulación
T (Oportuno):	4/5 - Típicamente mensual; podría ser más frecuente
I (Independiente):	4/5 - Bastante autónomo; no requiere contexto externo para interpretación
C (Costeable):	3/5 - Herramienta simulación phishing ~€2-5k/año; costo moderado
PRAGMATIC Score:	$(4+4+5+3+4+5+4+4+3) / 9 = 36/45 = 80\% \rightarrow$ BUENO
Recomendación:	ADOPTAR con advertencias: validar con datos reales de phishing para verificar predicción

PARTE VI: MATRIZ INTEGRATIVA GQM→PRAGMATIC

A continuación, una matriz que conecta:

National Objective – GQM Goal – GQM Questions – Metrics – PRAGMATIC Evaluation

[Ver documento complementario: "Matriz de Evaluación PRAGMATIC Completa"]

PARTE VII: DIRECTRICES DE IMPLEMENTACIÓN

VII.1 Selección de Métricas (Decision Tree)

Cuando una organización decide "¿cuáles métricas implementar?":

Paso 1: ¿Alineada con objetivo nacional/regulatorio?

SÍ → Paso 2

NO → Descartar (no justificable)

Paso 2: ¿PRAGMATIC Score $\geq$ 70%?

SÍ → Paso 3

NO → Revisar o descartar

Paso 3: ¿Fuente de datos disponible hoy (o <3 meses para implementar)?

SÍ → Paso 4

NO → Priorizar como "iniciativa futura"

Paso 4: ¿Presupuesto/recursos disponibles?

SÍ → IMPLEMENTAR

NO → Añadir a roadmap

Resultado: Portfolio de métricas "Quick Win" (listos ahora) vs. "Future" (próximos 6-12 meses)

VII.2 Roadmap de Implementación (Recomendado)

Trimestre	Fase	Métricas Prioritarias	Esfuerzo	Costo
Q1 2026	Quick Wins	MTTD, Patch Compliance, Training Completion, Phishing Click Rate	3 semanas	€10k
Q2 2026	Consolidación	MTTR, SAMM scores (Gobernanza, Design), SAST coverage	4 semanas	€15k
Q3 2026	Expansión	SIEM FP rate, Threat Model Coverage, Vuln Prioritization	6 semanas	€25k
Q4 2026	Optimización	Predictive Risk Models, Risk-adjusted ROI, Benchmarking	8 semanas	€40k

PARTE VIII: CONCLUSIÓN

Este **Marco Integrativo GQM+PRAGMATIC** proporciona:

- ✓ **Trazabilidad completa:** Objetivo Nacional → Estrategia → Goal → Question → Metric
- ✓ **Rigor metodológico:** Aplicación de GQM+Strategies (Basili, Fraunhofer) + PRAGMATIC (Brotby)
- ✓ **Evaluación objetiva:** Cada métrica evaluada contra 9 criterios con scoring cuantificado
- ✓ **Guía de implementación:** Priorización y roadmap operacional
- ✓ **Alineación regulatoria:** Todas las métricas tracean a NIS2, CRA, GDPR, SAMM v2

Resultado: Portfolio de métricas de **alta confianza, justificable y operacional** para ciberseguridad en España.